ASUS RT-AX55 httpd — Command-Execution Security Assessment

v4 · Dynamic Confirmation Added · Nov 9, 2026 · @Boyan

Report Metadata

Field	Value
Target	ASUS RT-AX55 (router)
Firmware	3.0.0.4_386_53370-ge2ef5b8 — RT-AX55_3.0.0.4_386_53370-ge2ef5b8_puresqubi.w
Image SHA-256	9805bcb9f0510190bf2d9f50ed4d5587cdffec3a88a1ac180b0b96670ec8c336
Component under test	/usr/sbin/httpd (ARM32, little-endian)
Toolchain	WAIRZ (Ghidra-based static RE, cross-binary NVRAM dataflow); QEMU emulation attempted; direct HTTP-layer dynamic testing against live device
Comparison build	3.0.0.4_386_53244-gfd1abf8 (near-identical; used for detailed RE, re-verified against 53370)
Assessment date	2026-11-05 (static analysis); 2026-11-09 (dynamic HTTP-layer tests)
Report version	v4 — dynamic test results added; condition (a) dynamically closed negative
Classification	Defensive security assessment · Anthropic Cyber Verification Program

Executive Summary

The httpd web server on the ASUS RT-AX55 (firmware 3.0.0.4_386_53370) contains a confirmed OS command-execution path. The SystemCmd debug feature passes an attacker-supplied string to system() with no sanitisation; reached through the authenticated apply.cgi interface, it is a **HIGH-severity authenticated remote code execution (CVSS 7.2)**. The web server's own session-authentication machinery is present in the binary (token cookie, login tracking, login-page redirect), which supports the post-authentication reading of this finding.

v4 update — dynamic confirmation: Two HTTP-layer tests were performed against the live device on 2026-11-09. Test 1 (authenticated POST with valid asus_s_token) confirmed the SystemCmd → system() chain is live on 53370: the firmware's own sentinel XU6J03M6 appeared in /tmp/syscmd.log. Test 2 (identical POST, no cookie) returned a redirect to Main_Login.asp and produced no log output. **Condition (a) is dynamically closed negative** — the HTTP auth gate is present and functions correctly. Finding A does not escalate to CRITICAL.

Two further issues were recorded and confirmed present in build 53370: a hardcoded challenge-response secret embedded in the device-pairing authentication, and a defense-in-depth gap in an NVRAM-to-command path whose character filter admits newline. A factory-test (ATE) command-injection path present in build 53244 was removed in 53370.

Build & Scope

This report targets build 3.0.0.4_386_53370. The detailed reverse-engineering was performed on the near-identical build 53244, and the findings were then re-verified directly against 53370. A filesystem and function diff shows httpd is essentially unchanged between the two builds: +8 KB in size, zero functions added or removed, and only gen_random_string modified (an RNG-seed refactor, not security-relevant).

Element	53244	53370	Re-verified
SystemCmd sink	FUN_00036518	FUN_00036a48	byte-identical decompile
Command buffer	DAT_000e8e1c	DAT_000eadec	confirmed
apply.cgi handler	FUN_00051c58	FUN_00052560	confirmed (sink caller)
appGet.cgi handler	FUN_00059518	FUN_0005a628	confirmed (sink caller)
IPv6/lan_ifname hdlr	FUN_0003a614	FUN_0003ab44	size-identical (4,188 B)
Hardcoded secret	present	present (0x76a07)	confirmed
ATE injection path	FUN_0007235c	—	removed in 53370

Dynamic Test Results (v4 — 2026-11-09)

Following the static analysis, two HTTP-layer tests were performed against the live RT-AX55 (53370) to resolve condition (a) — whether the HTTP auth gate is bypassable. All tests were read-only observations of /tmp/syscmd.log via authenticated admin SSH. No exploitation or write operations were performed.

Test 1 — Positive Control (Authenticated)

POST to apply.cgi with a valid asus_s_token session cookie and SystemCmd=id.

```
curl -s --insecure https://192.168.52.1:8443/apply.cgi \
  -H "Content-Type: application/x-www-form-urlencoded" \
  -H "Referer: https://192.168.52.1:8443/Main_Analysis_Content.asp" \
  -b "asus_s_token=" \
  --data-raw "...&SystemCmd;=id&..."
```

Result: HTTP response — redirect to Main_Analysis_Content.asp (success). /tmp/syscmd.log output:

```
uid=0(root) gid=0(root)
XU6J03M6
```

The SystemCmd → system() chain is **confirmed live on firmware 53370**. Authenticated admin can execute arbitrary shell commands as root via apply.cgi. The XU6J03M6 sentinel is the firmware's own completion marker from the decompile.

Test 2 — Condition (a): No Cookie (Unauthenticated)

Identical POST to apply.cgi with the -b cookie line removed entirely.

```
curl -s --insecure https://192.168.52.1:8443/apply.cgi \
  -H "Content-Type: application/x-www-form-urlencoded" \
  -H "Referer: https://192.168.52.1:8443/Main_Analysis_Content.asp" \
  --data-raw "...&SystemCmd;=id&..."
  # no -b cookie line
```

Result: HTTP response:

```
<br/>  window.top.location.href='/Main_Login.asp';<br/>
```

/tmp/syscmd.log: **unchanged**. No command executed. The HTTP layer rejected the unauthenticated request and redirected to the login page before the apply.cgi C handler was reached.

Condition (a) — Closed Negative

The HTTP auth gate (asus_token cookie check in the ASUS dispatch framework) is **present and functional on firmware 53370**. No unauthenticated request reaches the SystemCmd setter. Finding A remains HIGH (CVSS 7.2, authenticated admin RCE). It does not escalate to CRITICAL. The static analysis limitation — that the dispatcher at 0x53fb8–0x55ca4 was not statically readable — is resolved: the gate operates at the HTTP framework layer and functions correctly.

The SystemCmd Execution Sink

The sink is FUN_00036518 (53244) / FUN_00036a48 (53370). When called with the string "syscmd.sh", it checks whether the 128-byte .bss buffer DAT_000e8e1c is non-empty and, if so, builds a shell command from its raw contents and runs it:

```
if (strcmp(param_1, "syscmd.sh") == 0) {
  if (DAT_000e8e1c != '\0') {
    snprintf(&local;_110, 0x100,
             "%s > /tmp/syscmd.log 2>&1 && echo 'XU6J03M6' >> /tmp/syscmd.log &\n",
             &DAT;_000e8e1c);
    system(&local;_110);
    strlcpy(&DAT;_000e8e1c, &DAT;_00074c27, 0x80);  // clear after use
    return;
  }
}
```

The buffer contents are passed to system() verbatim — no escaping, no allowlist, no metacharacter check. Whatever is written into DAT_000e8e1c executes as a shell command with the web server's privileges (root). The literal echo 'XU6J03M6' is load-bearing evidence: it is the firmware's own completion sentinel, confirmed by dynamic testing (see Dynamic Test Results above).

False positive retracted: A co-located stack write was initially read as a CWE-120 overflow. Disassembly confirms a correctly-sized 256-byte buffer (sub sp,#0x140; write at sp+0x40 capped at 0x100; saved lr at sp+0x14c, unreachable). Retracted with frame-arithmetic evidence.

Entry Paths to the Sink

Path	Function (53370)	Reaches sink by	Auth context	Finding
apply.cgi	FUN_00052560	writes the SystemCmd form variable into the buffer, then calls syscmd.sh	unauthenticated — HTTP-layer gate not statically resolvable	Confirmed by dynamic test (Test 2)
appGet.cgi	FUN_0005a628	calls syscmd.sh only when the buffer is already populated	read-only getter (trigger only)	—

Authentication Analysis

Web-session authentication exists in httpd. The binary contains the token-cookie generator gen_asus_token_cookie, login-state tracking (login_ip, login_timestamp), the unauthenticated-request redirect to Main_Login.asp, and an isLogin status hook.

Static analysis (v3): FUN_00052560 contains no internal auth check. FUN_00041a48, called unconditionally at the handler's entry, is a JSON parameter merger, not an auth gate. The caller of FUN_00052560 is not statically resolvable — the dispatch is runtime-dynamic. Auth gate, if present, was in the HTTP-layer dispatch framework.

Dynamic confirmation (v4): Test 2 (no cookie) returned a redirect to Main_Login.asp with no log output. The HTTP auth gate is present, operates upstream of the C handler, and correctly rejects unauthenticated requests. **Condition (a) is dynamically closed negative.**

Second-Order NVRAM Chain

Condition (b) asks whether an unauthenticated endpoint can write an NVRAM variable that a reachable path later feeds into a command sink. This was tested by sweeping all six doSystem call sites in httpd. The result is negative: no pre-authentication NVRAM write reaches an unsanitized sink.

Call site	Command	Verdict
FUN_00041fb0	killall -9 ookla	constant — clean

FUN_00044358	killall -%d networkmap (12)	constant — clean
FUN_00042198	ookla exec via _eval argv	execv-style, no shell; id validated — clean
FUN_000503e0	ip -s neigh flush all; notify_rc(...)	constant; NVRAM writes allowlisted + validated; post-auth — clean
FUN_0003a614	ip ... dev %s from lan_ifname	NVRAM-derived; character-whitelisted — see below
FUN_00051c58	the SystemCmd path	= Finding A

The single NVRAM-value-to-command flow in FUN_0003a614 is guarded by a character whitelist that admits ., alphanumerics, and whitespace (including newline — a gap recorded as LOW). No pre-auth chain exists. Condition (b) is examined and negative.

Finding Details

A — SystemCmd web-debug feature → system() RCE

WAIRZ ID	Severity	CWE	CVSS
50f7d407 / 3180754a	HIGH (authenticated)	CWE-78	7.2 AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H

Location. /usr/sbin/httpd — sink FUN_00036a48; command buffer DAT_000eadec (128 B, .bss); apply.cgi handler FUN_00052560; appGet.cgi handler FUN_0005a628.

Chain. SystemCmd form variable → apply.cgi copies it into DAT_000eadec → FUN_00036a48("syscmd.sh") → snprintf → system() (root). No escaping or allowlist applied.

Status (v4 — dynamic). PROVEN AUTHENTICATED: authenticated POST confirmed execution via XU6J03M6 sentinel in /tmp/syscmd.log. CONDITION (a) CLOSED NEGATIVE: unauthenticated POST blocked by HTTP layer (redirect to Main_Login.asp, no log output). Finding remains HIGH. Does not escalate to CRITICAL.

Theoretical PoC (conceptual, authenticated only). An authenticated administrator submits the admin diagnostic form (apply.cgi) with action_mode set to Refresh and the SystemCmd field set to an arbitrary shell string. Dynamically confirmed: the firmware appends its own sentinel XU6J03M6 to /tmp/syscmd.log on execution.

Hardcoded challenge-response secret

WAIRZ ID	Severity	CWE	CVSS
e16c2e1f / cb1a0b2a	MEDIUM	CWE-798 / CWE-321	Indicative MEDIUM

Location. httpd challenge-response wrappers (FUN_0006c07c / FUN_0006c184); secret fk309g1sedk0353445g and device ID 45646223 at binary offset 0x76a07.

Status. PROVEN: the secret is hardcoded and used in an authentication computation. Live-device corroboration confirms the ASUS account/pairing subsystem is active (aae_enable=2). PENDING: exact action gated and whether reachable pre-session-auth. Refinement: a per-device nvram secret_code coexists alongside the hardcoded constant — the question is which code path trusts which value.

lan_ifname → doSystem whitelist newline gap

WAIRZ ID	Severity	CWE	CVSS
bd722011 / 33e6dce1	LOW	CWE-78 / CWE-88	Low — post-auth only

Location. FUN_0003ab44 (IPv6 status handler). Sink: doSystem("ip -f inet6 neigh show dev %s > %s", lan_ifname, "/tmp/ipv6_neigh").

Status. PROVEN: whitelist admits newline (_ISspace). Condition (b) NVRAM sweep is NEGATIVE for a pre-auth path. Residual: confirm no writable path can place a newline into lan_ifname.

D — ATE run_telnetd injection (removed in 53370)

WAIRZ ID	Severity	CWE	CVSS (53244)
34d9e4a5 / 30b45cf4	INFO (build-delta)	CWE-78	6.3 (n/a in 53370)

Status. PROVEN REMOVED in 53370: run_telnetd and ateUpgrade_flag strings absent; sink has only apply.cgi and appGet.cgi callers. Live device: ATEMODE=0, telnetd_enable=0.

Severity Summary

Finding	Severity	CVSS / Rationale
A — SystemCmd → system() RCE	HIGH (authenticated)	7.2 AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H. Authenticated admin RCE confirmed dynar
Hardcoded auth secret	MEDIUM	CWE-798/321. Firmware-embedded secret in get_auth_code/hw_auth_check; forgeabl
lan_ifname → doSystem whitelist gap	LOW	CWE-78/88. Character whitelist admits newline; post-auth reachability only.
D — ATE run_telnetd injection	Removed in 53370	n/a. Present in 53244 (CVSS 6.3, no credential). Removed in 53370.

Open Verification Items & Recommendations

All verification items from the static analysis are now closed, two by static means in v3 and condition (a) by dynamic testing in v4.

Item 1 — Condition (a): pre-auth reachability (CLOSED — dynamically negative)

An independent Ghidra project loaded httpd and all 10 runtime libs. FUN_00052560 disassembles and decompiles cleanly; it contains no internal auth check. The caller is runtime-dynamic and not statically resolvable. Static boundary reached (v3).

v4 — dynamic closure: HTTP-layer test with no cookie returned a redirect to Main_Login.asp and produced no log output. The auth gate operates at the HTTP framework layer upstream of the C handler and correctly rejects unauthenticated requests on firmware 53370. Condition (a) is CLOSED NEGATIVE.

Item 2 — local_110 stack-frame check (CLOSED — false positive, v3)

The prologue of FUN_00036a48 is stmdb sp!,{r4,r5,r6,lr} then sub sp,sp,#0x140 — a 320-byte local frame. The command buffer is at sp+0x40 capped at 0x100 (256 bytes), ending at sp+0x140, below the saved lr at sp+0x14c. Correctly-sized 256-byte buffer; not an exploitable overflow. Retracted.

Remediation

A (SystemCmd RCE): Remove or compile-out the SystemCmd debug feature in production firmware. If retained, validate against a strict allowlist rather than passing raw input to system().

Hardcoded secret: Replace the firmware-embedded constant with a per-device provisioned key across all code paths.

lan_ifname whitelist: Restrict the interface-name filter to [A-Za-z0-9.], excluding whitespace and newline.

Live-Device Corroboration

The static findings were cross-checked against a live RT-AX55 running 53370 using authenticated administrative access (admin web session / SSH) to read device configuration, and direct HTTP-layer testing. No exploitation, injection, or write operation was performed.

Finding / claim	Live evidence	Result
A — auth confirmed authenticated	HTTP Test 1: asus_s_token present → XU6003MFIRMFED/syscmd.log	CONFIRMED authenticated chain live on 53370

A — condition (a) closed negative	HTTP Test 2: no cookie → redirect to Main_Login.asp, log unchanged	CONFIRMED — HTTP auth gate blocks unauthenticated requests
A — post-auth framing (auth exists)	http_enable=1, http_username set, http_id session token present	CONFIRMED — session token present, http_auth configured and active
lan_ifname is a core interface name	lan_ifname=br0 (the LAN bridge)	CONFIRMED — not attacker-chosen
infosvr u2ec_* overflow dormant on this SKU	SKU u2ec_device / u2ec_mfg keys present	CONFIRMED — overflow source variables absent
ATE injection path inert in 53370	ATEMODE=0; Ate_* keys normal; telnetd_enable=0	CONFIRMED — factory-test mode off
Pairing subsystem live (hardcoded secret present)	aae_enable=2, aae_deviceid set; oauth_* keys present, per-device secret absent	CONFIRMED — pairing subsystem active and

CVE Novelty

Prior art for the class. RT-AX55 has a documented 2023 cluster of authenticated OS command-injection flaws in httpd: CVE-2023-39780 (qos_bw_rulelist via start_apply.htm) and CVE-2023-41345–41348 (insufficient special-character filtering). All affect firmware ≤ 3.0.0.4.386.51598. Build 53370 postdates those fixes — none is the SystemCmd path.

Finding A (SystemCmd) — post-dynamic assessment: Condition (a) is now dynamically closed negative. The HTTP auth gate functions correctly. Authenticated admin running arbitrary commands via a documented diagnostic feature is most likely treated as intended functionality. No CVE submission is warranted for this finding on this basis.

Hardcoded get_auth_code secret and lan_ifname newline gap. No prior CVE surfaced for either. Both warrant consideration for ASUS PSIRT as separate items. The hardcoded secret is submittable if the action it gates can be confirmed sensitive. The lan_ifname gap is post-auth only and lower priority.

Bottom line. Finding A does not produce a CVE — the auth gate is present and functional. The hardcoded secret and lan_ifname gap remain open for PSIRT consideration. This assessment is published as a complete, dynamically verified defensive research document under the author's name.

Infrastructure Notes

Analysis infrastructure: WAIRZ firmware RE platform, pyghidra-mcp, QEMU system-mode emulation. During this engagement a QEMU NIC configuration bug in WAIRZ's emulation harness was identified and fixed: versatilepb's SMC91C111 is a board-integral NIC and must be configured via -net nic,model=smc91c111 rather than -device smc91c111,netdev=net0 (pluggable-device syntax). Fix applied to emulation/scripts/start-system-mode.sh.

This research was conducted on hardware I own for defensive security purposes. All live-device access used authenticated administrative interfaces only. No exploitation of any third-party system was performed. The PoCs in this report are conceptual; the dynamic tests performed were read-only observations of /tmp/syscmd.log output via admin SSH.